Udyam Digital: data privacy and security note

Team NATPAT · TIET, Patiala · Airtel SYNC 2026

How the journey applies the DPDP Act, 2023: collect only what each step needs, ask before you look, keep it only as long as needed, show the owner what happened. **BUILT** marks what Udyam Digital does today; **AT LAUNCH** marks the steps a live rollout adds.

1 · WHAT EACH STEP COLLECTS, AND WHY

Step	Data	Purpose	Where it goes, who sees it
Advisor (web or WhatsApp)	Business type, size, sites, city, GST yes/no, goal, optional spend. No ID numbers asked	Recommend an eligible bundle	Claude, with GSTIN, PAN, Aadhaar, Udyam, phone and email removed first; WhatsApp threads kept by number
Sign-in	Mobile number, name; one-time code	Account and updates	Code stored only as a hash and expires automatically
Registry check	GSTIN or Udyam number (a proprietor's GSTIN embeds their PAN)	Confirm the business is real and active	Only after consent; encrypted at rest, always shown masked
Owner e-KYC (no GST or Udyam)	Aadhaar number, typed once (the check digit only catches typos). Verified by OTP through an authorised e-KYC partner (synthetic numbers in the demo)	Verify the owner of an unregistered business	Number discarded; only the result and last 4 digits kept, as on UIDAI's masked Aadhaar
Documents	Bill, signatory ID; for unregistered shops a licence or shop photo (image or PDF), read on the phone	Check names, address, dates, validity	Private bucket, no public link; only the owner and KYC/ops staff; every view logged
Order and field visit	Order, slot, address, delivery and install codes	Deliver, install, bill, support	Codes encrypted; field staff see a masked phone
Partner help	Case reason, city, language, owner's number	Call the owner who needs help	Full number only to the assigned partner; masked elsewhere

2 · SECURITY CONTROLS

- **BUILT** GSTIN and Udyam numbers encrypted with AES-256-GCM and looked up by keyed hash; Aadhaar numbers discarded after e-KYC; delivery and install codes encrypted; one-time codes hashed.
- **BUILT** OTP sign-in, an httpOnly session cookie (secure in production) and 7 roles. Each role reaches only its own screens and data, enforced on the server.
- **BUILT** The server recalculates every price and rule; inputs schema-validated; uploads JPEG, PNG, WebP or PDF up to 10 MB; rate limits on sign-in, Aadhaar OTP and WhatsApp.
- **BUILT** Audit log of consent, registry lookups, document views, KYC decisions and data requests. WhatsApp webhooks are signature-checked.
- **BUILT** Production mode refuses default secrets and turns off demo shortcuts (role switcher, on-screen codes).
- **AT LAUNCH** Keys in a managed vault; TLS for all traffic; signatory liveness check; Aadhaar e-sign; penetration test.

3 · DATA MINIMISATION BY DESIGN

- **BUILT** Registry first; documents only if still needed; verified once, reused for a year. Owners without GST are steered to free Udyam first; Aadhaar e-KYC is the fallback.
- **BUILT** Saying "we have GST" never unlocks GST-only products; only a verified GSTIN does.
- **BUILT** Switching to the no-registration path deletes uploaded certificates and signatory IDs; checks use only the declared business and e-KYC.
- **BUILT** Text is read on the device (OCR for photos, the text layer for PDFs); the OCR engine is served by our own app, not a CDN.
- **BUILT** The AI advisor never receives registry data or documents, and identifiers typed into the chat are removed first. The lead model uses profile fields only.

4 · CONSENT AND PURPOSE LIMITATION

- **BUILT** A plain notice in the owner's language before any check: what we check, why, and never for marketing.
- **BUILT** Consent is purpose-specific and recorded against the business and owner; every lookup and upload needs it. The 30-minute window only limits the session; fresh consent is asked when needed.
- **BUILT** Withdrawal stops further consent-based checks and is logged. Before verification, documents and identifiers are erased; after it, erasure requests are reviewed, and KYC a live service legally needs is kept only for that period.
- **AT LAUNCH** A registered DPDP consent manager; a separate marketing opt-in; approved WhatsApp templates.

5 · THIRD PARTIES AND TRANSFERS

- **Cloudflare R2**, **MongoDB**: processors under contract, in India or permitted regions.
- **UIDAI e-KYC**: via an authorised partner, with the owner's OTP consent each time.
- **Anthropic Claude** (advisor): screened chat text and profile buckets only; before launch, zero-retention terms and a permitted cross-border transfer.
- **Meta WhatsApp Cloud API**: processes phone numbers and whatever the owner types. No documents are asked for there; identifiers are removed before AI processing.

6 · OWNER RIGHTS AND ACCOUNTABILITY

- **BUILT** Each KYC check shows why it passed or failed; "ask a reviewer".
- **BUILT** My data: see consents and documents; ask for access, correction or erasure from the OTP-signed-in account, so the owner is identified. Requests get a due date. Grievance officer named on every page.
- **AT LAUNCH** Incident response with breach assessment and notification to the Data Protection Board; a DPIA; quarterly bias review of the lead model by language and city tier.

7 · RETENTION

Data	Today	At launch
Consent	30 min per grant; record kept	Consent evidence for the statutory period
One-time codes	Hashed; auto-expire	Same
KYC documents	Replaced files deleted; erased on withdrawal or request	Deleted after verification unless telecom KYC rules require it
Abandoned quotes	Kept, with a reminder after 24 h	Erased after 30 days
WhatsApp, leads, registry results, audit log, backups	No automatic expiry yet	A documented operational or legal period, then deleted or anonymised, backups included

All data is synthetic, from the case pack. A design note, not proof of compliance: confirm retention against DPDP rules and telecom KYC conditions.